

**BỘ GIÁO DỤC VÀ ĐÀO TẠO
TRƯỜNG ĐẠI HỌC ĐẠI NAM**



BÀI TẬP LỚN

TÊN HỌC PHẦN: AN TOÀN BẢO MẬT THÔNG TIN

**ĐỀ TÀI: NGHIÊN CỨU CHUYÊN SÂU VỀ CƠ CHẾ TẤN CÔNG, KỸ
THUẬT PHÁT HIỆN VÀ CHIẾN LƯỢC PHÒNG VỆ ĐỐI VỚI HIỂM HỌA
DENIAL-OF-SERVICE (DỰA TRÊN CHƯƠNG TRÌNH CHUẨN CEH
MODULE 09)**

STT	Mã Sinh Viên	Họ và Tên	Ngày Sinh	Lớp
1	1871020291	PHẠM QUANG HUY	06/11/2005	CNTT18-12
2	1871020597	Nguyễn Quang Trung	27/11/2006	CNTT18-12
3		Lê Ngọc Thái		

Hà Nội, năm 2026

**BỘ GIÁO DỤC VÀ ĐÀO TẠO
TRƯỜNG ĐẠI HỌC ĐẠI NAM**



BÀI TẬP LỚN

TÊN HỌC PHẦN: AN TOÀN BẢO MẬT THÔNG TIN

**ĐỀ TÀI:NGHIÊN CỨU CHUYÊN SÂU VỀ CƠ CHẾ TẤN CÔNG, KỸ
THUẬT PHÁT HIỆN VÀ CHIẾN LƯỢC PHÒNG VỆ ĐỐI VỚI HIỂM HỌA
DENIAL-OF-SERVICE (DỰA TRÊN CHƯƠNG TRÌNH CHUẨN CEH
MODULE 09)**

STT	Mã Sinh Viên	Họ và Tên	Ngày Sinh	Điểm	
				Bảng Số	Bảng Chữ
1	1871020291	PHẠM QUANG HUY	06/11/2005		
2	1871020597	NGUYỄN QUANG TRUNG	27/11/2006		

CÁN BỘ CHẤM THI 1

CÁN BỘ CHẤM THI 2

Hà Nội, Năm 2026

LỜI NÓI ĐẦU

1. Tính cấp thiết của đề tài

Trong kỷ nguyên số hóa, hạ tầng mạng Internet đóng vai trò là mạch máu cốt lõi thúc đẩy toàn bộ nền kinh tế, xã hội toàn cầu. Sự phụ thuộc ngày càng lớn vào không gian mạng cũng mở ra những thách thức an ninh vô cùng khốc liệt. Giữa bối cảnh đó, tấn công Từ chối dịch vụ (Denial-of-Service - DoS) và Từ chối dịch vụ phân tán (Distributed Denial-of-Service - DDoS) nổi lên như một trong những hiểm họa công nghệ nguy hiểm, phổ biến và khó phòng chống nhất.

Sự tiến hóa của các cuộc tấn công DoS/DDoS không còn dừng lại ở các phương thức làm tràn ngập băng thông truyền thống mà đã chuyển dịch mạnh mẽ sang các kỹ thuật tinh vi như tấn công tầng ứng dụng (Layer 7 Flooding), tấn công phản xạ khuếch đại (DRDoS) tận dụng lỗ hổng cấu hình của các giao thức không hướng kết nối (UDP, NTP, Memcached), hay thậm chí là phá hoại vĩnh viễn phần cứng thiết bị (Phlashing). Với sự trợ giúp của các mạng lưới máy tính ma (Botnet) xuyên quốc gia và các công cụ tấn công mã nguồn mở được tối ưu hóa như HOIC, HULK, DoSHTTP, tội phạm mạng có thể dễ dàng vắt kiệt tài nguyên của những hệ thống máy chủ lớn chỉ trong vài giây.

Hậu quả của một cuộc tấn công DDoS không chỉ là sự gián đoạn dịch vụ tức thời, gây thiệt hại nặng nề về mặt tài chính do ngưng trệ giao dịch, mà còn làm xói mòn nghiêm trọng uy tín, danh tiếng của tổ chức và có khả năng đe dọa đến an ninh quốc gia. Do đó, việc nghiên cứu toàn diện về cơ chế hoạt động, kỹ thuật phát hiện, các kịch bản kiểm thử và chiến lược ứng phó đối với tấn công DoS/DDoS là một yêu cầu cấp thiết, đóng vai trò nền tảng để xây dựng hệ thống phòng thủ vững chắc cho mọi tổ chức trong tình hình mới.

2. Mục tiêu nghiên cứu

Nghiên cứu này được thực hiện nhằm đạt được các mục tiêu cốt lõi sau:

- **Hệ thống hóa lý thuyết nâng cao:** Phân tích chuyên sâu kiến trúc, nguyên lý vận hành và phân loại của các dạng tấn công DoS/DDoS dựa trên mô hình chuẩn hóa CEH.

- **Giải mã kỹ thuật cốt lõi:** Làm rõ cơ chế lan truyền mã độc của mạng lưới Botnet, các thuật toán tìm kiếm máy trạm dễ tổn thương và bản chất của hệ số khuếch đại (Amplification Factor) trong tấn công DRDoS.
- **Đánh giá giải pháp phát hiện và phòng vệ:** Phân tích các thuật toán định lượng (CUSUM, biến đổi Wavelet, Lập hồ sơ hoạt động) dùng để phát hiện bất thường luồng mạng, từ đó đề xuất ma trận chiến lược countermeasures (hấp thu, hạ cấp hoặc cô lập dịch vụ) tối ưu.
- **Thực nghiệm kiểm thử xâm nhập:** Xây dựng quy trình giả lập tấn công có kiểm soát trong môi trường Lab, phân tích log giám sát dữ liệu thực tế bằng các công cụ chuyên dụng để tìm ra điểm gãy (Breaking Point) của hệ thống web, phục vụ công tác khắc phục lỗi hỏng chủ động.

3. Đối tượng và phạm vi nghiên cứu

- **Đối tượng nghiên cứu:** Các véc-tơ tấn công từ chối dịch vụ (Volumetric, Fragmentation, TCP State-Exhaustion, Application Layer Attacks), cấu trúc mạng lưới Botnet độc hại, công cụ tấn công chuyên dụng và các giải pháp/ thuật toán phòng thủ tương ứng.
- **Phạm vi nghiên cứu:** Đề tài tập trung nghiên cứu chuyên sâu dựa trên khung kiến thức bảo mật chuẩn CEH Module 09 (Denial-of-Service). Các nội dung thực nghiệm, phân tích gói tin mạng và cấu hình luật tường lửa được giới hạn thực hiện trong môi trường Lab giả lập an toàn, sử dụng hệ điều hành Kali Linux và Ubuntu Server, không gây ảnh hưởng đến hệ thống mạng thực tế.

Mục Lục

CHƯƠNG I: TỔNG QUAN VỀ TẤN CÔNG TỪ CHỐI DỊCH VỤ (DOS/DDOS CONCEPTS) 10

1. Định nghĩa kỹ thuật 10
2. Bản chất của Tấn công từ chối dịch vụ phân tán (DDoS - Distributed Denial of Service) 10

CHƯƠNG II: BA CHIẾN LƯỢC VÀ PHƯƠNG PHÁP LAN TRUYỀN MÃ ĐỘC CỦA TỘI PHẠM MẠNG (MALICIOUS PROPAGATION TECHNIQUES) 12

1. Kỹ thuật Lan truyền từ Nguồn Tập trung (Central Source Propagation)..... 12
2. Kỹ thuật Lan truyền Chuỗi ngược (Back-chaining Propagation) 12
3. Kỹ thuật Lan truyền Tự trị (Autonomous Propagation)..... 13

CHƯƠNG III: BỐN PHÂN LOẠI VÉC-TƠ TẤN CÔNG DOS/DDOS NÂNG CAO (ATTACK VECTORS) 14

1. Tấn công Thở tích / Băng thông (Volumetric Attacks) 14
2. Tấn công Mảnh vỡ (Fragmentation Attacks) 15
3. Tấn công Kiệt quệ Trạng thái TCP (TCP State-Exhaustion Attacks)..... 15
4. Tấn công Tầng Ứng dụng (Application Layer Attacks)..... 15

CHƯƠNG IV: CƠ CHẾ SÂU CỦA CÁC KỸ THUẬT TẤN CÔNG THỰC TẾ (DETAILED ATTACK TECHNIQUES) 16

1. Tấn công lụt gói tin SYN (SYN Attacks & SYN Flooding) 16
2. Tấn công qua mạng ngang hàng (Peer-to-Peer Attacks) 16
3. Tấn công từ chối dịch vụ vĩnh viễn (Permanent Denial-of-Service / Phlashing)..... 17

CHƯƠNG V: KIẾN TRÚC VÀ HỆ SINH THÁI MẠNG LƯỚI MÁY TÍNH MA (BOTNET NETWORKS)..... 18

1. Quy trình thiết lập và điều khiển Botnet 18

2. Mô hình phân cấp cấu trúc tội phạm mạng có tổ chức (Organized Cyber Crime)	18
3. Năm phương pháp quét mạng tìm kiếm máy trạm dễ tổn thương (Scanning Methods)	19
CHƯƠNG VI: CÁC KỸ THUẬT PHÁT HIỆN TẤN CÔNG DOS/DDOS (DETECTION TECHNIQUES).....	21
1. Kỹ thuật Lập hồ sơ hoạt động (Activity Profiling)	21
2. Kỹ thuật Phân tích tín hiệu dựa trên Wavelet (Wavelet-based Signal Analysis).....	21
CHƯƠNG VII: CHIẾN LƯỢC VÀ CÔNG CỤ ỨNG PHÓ TRONG PHÒNG VỆ (COUNTERMEASURES)	23
1. Ba chiến lược ứng phó cốt lõi (Countermeasure Strategies).....	23
CHƯƠNG VIII: QUY TRÌNH KIỂM THỬ XÂM NHẬP DOS/DDOS (PENETRATION TESTING)	25
Bước 1: Giành quyền chấp thuận bằng văn bản (Written Permission & SLA)	25
Bước 2: Thu thập thông tin và xác định bề mặt tấn công (Reconnaissance)	26
Bước 3: Lập kịch bản và lựa chọn công cụ phù hợp	26
Bước 4: Thiết lập môi trường giám sát nền (Monitoring Baseline)	26
Bước 5: Thực hiện tấn công leo thang có kiểm soát (Execution)	27
Bước 6: Khôi phục hệ thống và lập báo cáo kiến nghị (Remediation & Reporting)	27
CHƯƠNG IX: PHÂN TÍCH CHUYÊN SÂU KIẾN TRÚC VÀ CƠ CHẾ KHUẾCH ĐẠI TRONG TẤN CÔNG PHẢN XẠ (DRDOS AMPLIFICATION METRICS)	28
1. Bản chất kỹ thuật của việc lựa chọn giao thức UDP	28
2. Bảng thống kê hệ số khuếch đại của các giao thức phổ biến	28
CHƯƠNG X: QUY TRÌNH GIÁM SÁT VÀ ĐIỀU TRA SỰ CỐ DDOS DÀNH CHO ĐỘI NGŨ AN NINH (SOC DRILL)	31
Bước 1: Trích xuất gói tin bằng công cụ lệnh TSHARK	31
Bước 2: Phân tích thống kê tìm địa chỉ IP nguồn tấn công	32

Bước 3: Cấu hình quy tắc tường lửa IPTABLES để chặn khẩn cấp	32
CHƯƠNG XI: MA TRẬN SO SÁNH GIỮA CÁC CÔNG CỤ TẤN CÔNG DOS/DDOS PHỔ BIẾN PHƯƠNG PHÁP LUẬN VÀ KẾT LUẬN BÁO CÁO.....	34
1. Phương pháp luận phòng thủ toàn diện.....	35
2. Kết luận.....	36
PHỤ LỤC A: TỪ ĐIỂN THUẬT NGỮ KỸ THUẬT CHUYÊN SÂU (GLOSSARY).....	36
PHỤ LỤC B: DANH MỤC TÀI LIỆU THAM KHẢO	38

CHƯƠNG I: TỔNG QUAN VỀ TẤN CÔNG TỪ CHỐI DỊCH VỤ (DOS/DDOS CONCEPTS)

1. Định nghĩa kỹ thuật

- **Tấn công từ chối dịch vụ (DoS - Denial of Service):** Là một hành vi phá hoại nhằm vào máy tính hoặc tài nguyên hệ thống mạng mạng, nhằm mục đích làm giảm, hạn chế hoặc ngăn chặn hoàn toàn khả năng truy cập hợp lý của người dùng hợp lệ vào các tài nguyên hoặc dịch vụ của hệ thống đó (p. 5).
- **Cơ chế cốt lõi:** Kẻ tấn công sẽ gửi liên tiếp một lượng khổng lồ các yêu cầu dịch vụ bất hợp pháp hoặc lưu lượng truy cập rác vào hệ thống mục tiêu. Mục đích là để làm quá tải tài nguyên tính toán (CPU, RAM) hoặc chiếm dụng hoàn toàn băng thông đường truyền kết nối Internet (p. 5).
- **Hệ quả trực tiếp:** Cuộc tấn công dẫn đến tình trạng một trang web cụ thể hoàn toàn không thể truy cập được từ bên ngoài hoặc khiến cho hiệu năng hoạt động của toàn hệ thống mạng bị chậm đi rõ rệt (p. 5).

2. Bản chất của Tấn công từ chối dịch vụ phân tán (DDoS - Distributed Denial of Service)

- **Khái niệm:** Khác với DoS chỉ sử dụng một nguồn tấn công duy nhất, một cuộc tấn công DDoS sẽ huy động một số lượng khổng lồ các hệ thống máy tính đã bị thỏa hiệp (bị nhiễm độc và chiếm quyền kiểm soát) trên toàn cầu cùng đồng loạt tấn công vào một mục tiêu đơn lẻ (p. 6).
- **Phương thức triển khai:** Để phát động một chiến dịch DDoS trên diện rộng, kẻ tấn công bắt buộc phải sử dụng các mạng lưới máy tính ma (Botnet) (p. 6). Lưu lượng rác từ hàng ngàn nguồn IP khác nhau dồn về cùng một thời điểm sẽ bẻ gãy mọi bộ lọc an ninh thông thường.
- **Bốn tác động nghiêm trọng của DoS/DDoS đối với tổ chức:**
 - *Loss of Goodwill (Tổn hại danh tiếng):* Làm mất đi lòng tin của khách hàng và đối tác khi dịch vụ trực tuyến liên tục bị gián đoạn (p. 6).

- *Disabled Network (Vô hiệu hóa hệ thống mạng)*: Hạ tầng mạng của toàn doanh nghiệp bị tê liệt hoàn toàn, không thể truyền tải dữ liệu nội bộ và ra ngoài (p. 6).
- *Financial Loss (Thiệt hại nặng nề về mặt tài chính)*: Gây thất thoát doanh thu trực tiếp do ngưng trệ các hoạt động giao dịch trực tuyến và tổn chi phí khắc phục sự cố (p. 6).
- *Disabled Organization (Tê liệt toàn bộ tổ chức)*: Toàn bộ quy trình vận hành, nhân sự và các phòng ban của doanh nghiệp bị đình trệ do không thể tiếp cận các ứng dụng và tài nguyên số cốt lõi (p. 6).

CHƯƠNG II: BA CHIẾN LƯỢC VÀ PHƯƠNG PHÁP LAN TRUYỀN MÃ ĐỘC CỦA TỘI PHẠM MẠNG (MALICIOUS PROPAGATION TECHNIQUES)

Để xây dựng được mạng lưới Botnet phục vụ cho mục đích DDoS, kẻ tấn công áp dụng các kỹ thuật tinh vi sau nhằm phát tán mã độc (Malicious Code) vào các hệ thống mục tiêu mới phát hiện (p. 25).

1. Kỹ thuật Lan truyền từ Nguồn Tập trung (Central Source Propagation)

- **Cơ chế hoạt động:** Kẻ tấn công thiết lập và đặt toàn bộ hộp công cụ tấn công mã độc (Attack Toolkit) trên một máy chủ nguồn trung tâm (Central Source) cố định (p. 25).
- **Quy trình thực thi:**
 1. Kẻ tấn công phát lệnh khai thác lỗ hổng (Exploit) thành công lên máy nạn nhân thứ nhất (Victim) (p. 25).
 2. Một lệnh tải tệp tự động được thực thi trên máy nạn nhân để kết nối trực tiếp về máy chủ trung tâm nhằm sao chép mã độc (Copy Code) sang hệ thống mới này (p. 25).
 3. Quy trình này lặp đi lặp lại liên tục (Repeat) để biến máy nạn nhân tiếp theo (Next Victim) thành một trạm phát tán mới (p. 25).

2. Kỹ thuật Lan truyền Chuỗi ngược (Back-chaining Propagation)

- **Cơ chế hoạt động:** Thay vì sử dụng một máy chủ trung tâm độc lập, kẻ tấn công cấu hình và đặt hộp công cụ tấn công trực tiếp ngay trên chính hệ thống máy tính cá nhân của mình (p. 25).
- **Quy trình thực thi:**
 1. Kẻ tấn công thực hiện hành vi khai thác lỗ hổng (Exploit) đối với máy nạn nhân (p. 25).
 2. Ngay lập tức, một kênh kết nối ngược (Back-chaining connection) từ máy nạn nhân sẽ được thiết lập tự động để quay trở về máy của kẻ tấn công để lấy bản sao của hộp công cụ mã độc (Copy Code) (p. 25).

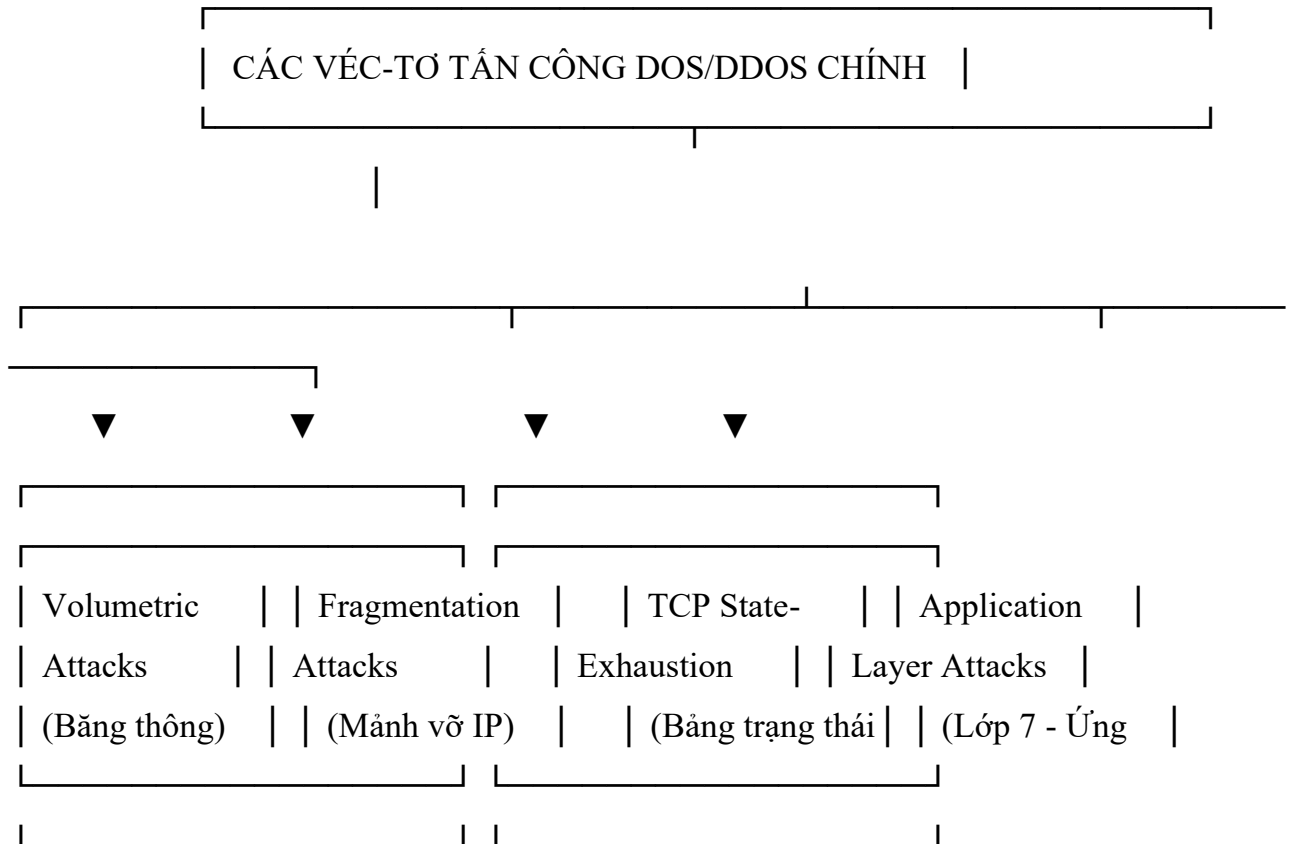
3. Quá trình này diễn ra song song với việc liên tục quét mạng để tìm kiếm và lây nhiễm cho máy nạn nhân tiếp theo (Next Victim) (p. 25).

3. Kỹ thuật Lan truyền Tự trị (Autonomous Propagation)

- **Cơ chế hoạt động:** Đây là phương thức nguy hiểm và có tốc độ lây lan nhanh nhất do không phụ thuộc vào bất kỳ máy chủ trung gian nào. Hộp công cụ tấn công mã độc sẽ được truyền tải đi đồng thời cùng với gói tin khai thác lỗ hổng ngay tại thời điểm hệ thống dễ bị tổn thương mới được phát hiện (p. 25).
- **Quy trình thực thi:**
 1. Kẻ tấn công gửi một gói tin tổng hợp chứa cả mã khai thác lỗ hổng và mã độc sao chép hệ thống (Exploit and Copy Code) đến máy nạn nhân (p. 25).
 2. Khi lỗ hổng bị kích hoạt, mã độc tự động chạy độc lập mà không cần tải thêm bất kỳ tệp nào từ bên ngoài (p. 25).
 3. Máy nạn nhân lập tức biến thành một thực thể tự trị, tự động quét mạng và lặp lại (Repeat) toàn bộ quy trình này lên máy nạn nhân kế tiếp (Next Victim) (p. 25).

CHƯƠNG III: BỐN PHÂN LOẠI VÉC-TƠ TẤN CÔNG DOS/DDOS NÂNG CAO (ATTACK VECTORS)

Theo chuẩn hóa kiến thức bảo mật CEH, toàn bộ các hình thức tấn công từ chối dịch vụ được chia thành 4 nhóm véc-tơ cốt lõi nhắm vào các tầng cấu trúc hạ tầng khác nhau (p. 9):



1. Tấn công Thể tích / Băng thông (Volumetric Attacks)

- **Bản chất kỹ thuật:** Là hình thức tấn công sử dụng luồng lưu lượng rác khổng lồ nhằm tiêu thụ và làm nghẽn hoàn toàn băng thông đường truyền (bandwidth) của mạng lưới hoặc dịch vụ mục tiêu (p. 9).
- **Cơ chế hoạt động:** Do một máy đơn lẻ không thể tạo đủ lưu lượng để bóp nghẹt thiết bị mạng, kẻ tấn công huy động hàng hàng botnet gửi liên tiếp các gói tin như ICMP ECHO (Ping Flood) (p. 10). Khi băng thông bị chiếm dụng hết, các gói tin hợp lệ của người dùng sẽ bị Drop hoàn toàn tại cổng định tuyến (p. 10).

2. Tấn công Mảnh vỡ (Fragmentation Attacks)

- **Bản chất kỹ thuật:** Nhóm tấn công này nhắm vào cơ chế phân mảnh gói tin của giao thức IP khi truyền tải qua các môi trường mạng có kích thước MTU (Maximum Transmission Unit) khác nhau.
- **Cơ chế hoạt động:** Kẻ tấn công gửi dồn dập các gói tin bị cố tình làm sai lệch, phân mảnh nghiêm trọng hoặc thiếu hụt các mảnh vỡ cốt lõi. Hành vi này làm quá tải và phá vỡ năng lực re-assembling (tái lắp ráp) các gói tin bị phân mảnh của thiết bị tường lửa hoặc hệ điều hành máy chủ mục tiêu, gây treo cứng hệ thống (p. 9).

3. Tấn công Kiệt quệ Trạng thái TCP (TCP State-Exhaustion Attacks)

- **Bản chất kỹ thuật:** Thay vì làm nghẽn băng thông đường truyền, véc-tơ này tập trung làm cạn kiệt bảng lưu trữ trạng thái kết nối (connection state tables) của các thiết bị hạ tầng lõi (p. 9).
- **Cơ chế hoạt động:** Mọi thiết bị mạng như bộ cân bằng tải (Load-balancers), tường lửa (Firewalls) và máy chủ ứng dụng (Application servers) đều có một dung lượng bộ nhớ giới hạn để quản lý các phiên kết nối đang diễn ra (p. 9). Kẻ tấn công thiết lập liên tục hàng triệu phiên kết nối giả mạo nhưng không bao giờ hoàn tất hoặc đóng kết nối, khiến bảng trạng thái bị lấp đầy hoàn toàn, từ chối mọi kết nối mới từ người dùng thật.

4. Tấn công Tầng Ứng dụng (Application Layer Attacks)

- **Bản chất kỹ thuật:** Là hình thức tấn công nhắm sâu vào lớp 7 (Application Layer) của mô hình OSI, trực tiếp tiêu thụ các tài nguyên xử lý logic của phần mềm hoặc dịch vụ ứng dụng (p. 9).
- **Cơ chế hoạt động:** Kẻ tấn công khai thác triệt để các điểm yếu, lỗi lập trình trong mã nguồn ứng dụng (programming source code) để ngăn chặn việc xử lý các yêu cầu hợp lệ (p. 17). Bằng cách gửi các yêu cầu HTTP nặng hoặc các câu lệnh truy vấn cơ sở dữ liệu (SQL query) độc hại được thiết kế tinh vi, kẻ tấn công có thể làm nghẽn kết nối cơ sở dữ liệu (application-database connection) hoặc khóa tài khoản người dùng bằng cách giả lập liên tiếp các hành vi đăng nhập sai (invalid login attempts)

CHƯƠNG IV: CƠ CHẾ SÂU CỦA CÁC KỸ THUẬT TẤN CÔNG THỰC TẾ (DETAILED ATTACK TECHNIQUES)

1. Tấn công lụt gói tin SYN (SYN Attacks & SYN Flooding)

- **Nguyên lý lỗ hổng ba bước (Three-way Handshake):** Giao thức TCP thiết lập kết nối tin cậy qua 3 bước tiêu chuẩn: Host A gửi gói SYN $\rightarrow$ Host B phản hồi SYN-ACK và đưa kết nối vào một hàng đợi lắng nghe (Listen Queue) để chờ gói ACK xác nhận cuối cùng từ Host A.
- **Điểm yếu thời gian duy trì:** Theo mặc định, hầu hết các hệ điều hành bắt buộc phải duy trì và theo dõi thông tin của các kết nối mở lửng (Half-open connection) này trong một khoảng thời gian lên tới **75 giây** (p. 13).
- **Cơ chế khai thác:** Kẻ tấn công gửi liên tục một số lượng khổng lồ các gói tin yêu cầu SYN tới máy chủ mục tiêu với các địa chỉ IP nguồn hoàn toàn giả mạo (fake source IP addresses) (p. 12). Máy chủ phản hồi gói SYN-ACK vào không trung và treo kết nối để chờ đợi phản hồi trong 75 giây (pp. 12-13).
- **Hệ quả hệ thống:** Do dung lượng hàng đợi listen queue của máy chủ có giới hạn nhỏ, việc giữ hàng vạn kết nối lửng cùng lúc sẽ làm **hàng đợi bị lấp đầy lập tức (quickly filled up)** (p. 13). Hệ thống mất hoàn toàn khả năng tiếp nhận các yêu cầu bắt tay hợp lệ từ người dùng thực tế.

2. Tấn công qua mạng ngang hàng (Peer-to-Peer Attacks)

- **Cơ chế điều hướng luồng dữ liệu:** Kẻ tấn công không trực tiếp gửi lưu lượng từ máy mình mà tiến hành khai thác các điểm yếu bảo mật tồn tại trong cấu trúc của giao thức chia sẻ tệp mạng ngang hàng, phổ biến là giao thức DC++ (Direct Connect) dùng cho các phần mềm nhắn tin và chia sẻ dữ liệu (p. 14).
- **Phương thức thực thi:** Kẻ tấn công gửi các câu lệnh độc hại để đánh lừa và ép buộc hàng loạt các máy trạm khách (Clients) đang tham gia trong các trục chia sẻ file P2P phải ngắt kết nối khỏi mạng lưới hiện tại (p. 14).
- **Hệ quả trực tiếp:** Các máy trạm này bị điều hướng tự động, đồng loạt thực hiện kết nối dồn dập về địa chỉ IP hoặc trang web giả mạo của nạn nhân (p. 14). Cuộc tấn

công tận dụng chính băng thông của người dùng mạng ngang hàng vô tội để tạo ra một trận lụt dữ liệu DDoS khổng lồ làm sập website mục tiêu (p. 14).

3. Tấn công từ chối dịch vụ vĩnh viễn (Permanent Denial-of-Service / Phlashing)

- **Bản chất phá hoại vật lý:** Khác với tất cả các dạng tấn công DoS thông thường chỉ gây nghẽn mạng tạm thời, Permanent DoS (còn gọi là Phlashing) nhắm thẳng vào mục đích gây ra các hư hại không thể đảo ngược (irreversible damage) đối với phần cứng hệ thống vật lý (p. 15).
- **Cơ chế "Bricking a system" (Biến thiết bị thành gạch vụn):** Kẻ tấn công sử dụng các kỹ thuật như gửi email độc hại, tin nhắn qua kênh chat IRC, tweet hoặc Post video chứa các liên kết lừa đảo tinh vi (p. 15). Khi nạn nhân sập bẫy, kẻ tấn công chiếm quyền truy cập sâu vào máy tính hoặc thiết bị mạng của họ và đẩy các bản cập nhật phần sụn (fraudulent hardware/firmware updates) giả mạo vào thiết bị (p. 15).
- **Hậu quả tối cao:** Khi mã độc được thực thi bên trong chip ROM, firmware của thiết bị sẽ bị ghi đè hoàn toàn bởi dữ liệu rác hoặc mã lỗi (p. 15). Thiết bị vật lý bị tê liệt hoàn toàn, không thể khởi động lại được, ép buộc tổ chức nạn nhân phải bỏ chi phí lớn để thay thế hoặc cài đặt lại toàn bộ phần cứng mới (p. 15).

CHƯƠNG V: KIẾN TRÚC VÀ HỆ SINH THÁI MẠNG LƯỚI MÁY TÍNH MA (BOTNET NETWORKS)

1. Quy trình thiết lập và điều khiển Botnet

Mạng lưới Botnet hoạt động như một hệ thống phân cấp quân đội số, được vận hành chặt chẽ qua 6 bước cốt lõi (p. 21):

1. **Thiết lập hạ tầng:** Kẻ tấn công thiết lập máy chủ điều khiển Bot Command and Control Center (C&C Center) và cài đặt một trình xử lý điều khiển (C&C Handler) (p. 21).
2. **Xâm nhập ban đầu:** Kẻ tấn công tiến hành dò quét và thực hiện hành vi lây nhiễm mã độc thành công lên một máy nạn nhân đầu tiên (Victim/Bot) (p. 21).
3. **Tự động nhân bản:** Mã độc trên máy Bot này tự động quét môi trường mạng xung quanh, tìm kiếm các hệ thống có lỗ hổng tương tự để lây nhiễm, tự động mở rộng quy mô mạng lưới Botnet (p. 21).
4. **Kết nối đăng ký:** Tất cả các máy tính bị chiếm quyền (Zombies) tự động thực hiện kết nối ngược về máy chủ C&C Handler để báo cáo trạng thái trực tuyến và chờ đợi lệnh (p. 21).
5. **Phát lệnh tập trung:** Khi cần tấn công, kẻ tấn công chỉ cần gửi duy nhất một dòng lệnh xuống máy chủ C&C (p. 21). Hệ thống C&C sẽ tự động phân phối lệnh đồng loạt đến hàng vạn máy Zombie cùng lúc (p. 21).
6. **Đồng loạt xả lũ:** Toàn bộ mạng lưới máy ma nhận lệnh, đồng loạt hướng luồng dữ liệu tấn công (như ICMP Echo Flood) về phía máy chủ mục tiêu (Target Server), làm tê liệt dịch vụ ngay lập tức (p. 21).

2. Mô hình phân cấp cấu trúc tội phạm mạng có tổ chức (Organized Cyber Crime)

Trong thế giới ngầm, việc vận hành Botnet được chuyên môn hóa cao theo mô hình doanh nghiệp kim tự tháp (p. 20):

- **Criminal Boss (Trùm tội phạm):** Đứng ở đỉnh kim tự tháp, điều hành toàn bộ chiến dịch, đưa ra mục tiêu chiến lược và phân phối lợi nhuận tài chính (p. 20).

- **Underboss (Trùm phó / Nhà cung cấp Trojan):** Trực tiếp quản lý và vận hành kỹ thuật hệ thống lệnh Trojan Command and Control; phân phối các bộ công cụ tạo mã độc (Crimeware Toolkit Owners) xuống cấp dưới (p. 20).
- **Campaign Manager (Quản lý chiến dịch):** Điều phối các hoạt động phát tán mã độc cụ thể, chịu trách nhiệm nhúng Trojan vào các website hợp pháp để bẫy người dùng (p. 20).
- **Affiliation Network (Mạng lưới đại lý liên kết):** Các nhóm tin tặc cấp thấp thực hiện nhiệm vụ phát tán, lây nhiễm mã độc trên diện rộng để xây dựng và cho thuê quyền lực Botnet (p. 20).
- **Stolen Data Reseller (Bên trung gian bán dữ liệu đánh cắp):** Thu thập thông tin thẻ tín dụng, tài khoản ngân hàng từ hệ sinh thái Botnet để bán lại ra thị trường đen (p. 20).

3. Năm phương pháp quét mạng tìm kiếm máy trạm dễ tổn thương (Scanning Methods)

Để tuyển dụng thêm các máy Zombie mới, mã độc Botnet áp dụng 5 thuật toán dò quét tự động sau (p. 24):

- **Random Scanning (Quét ngẫu nhiên):** Máy bị nhiễm tự động phát các gói tin kiểm tra lỗ hổng tới các địa chỉ IP được chọn hoàn toàn ngẫu nhiên trong toàn bộ không gian mạng Internet (p. 24).
- **Hit-list Scanning (Quét theo danh sách có sẵn):** Kẻ tấn công thu thập từ trước một danh sách các máy chủ có tiềm năng chứa lỗ hổng lớn, sau đó ra lệnh cho Botnet quét tập trung vào danh sách này để đẩy nhanh tiến độ chiếm quyền (p. 24).
- **Topological Scanning (Quét theo cấu trúc liên kết):** Mã độc tận dụng chính các thông tin nội bộ thu thập được trên máy đã bị nhiễm (như lịch sử duyệt web, danh bạ email, bảng định tuyến) để tìm ra và tấn công các mục tiêu có liên quan (p. 24).
- **Local Subnet Scanning (Quét mạng con nội bộ):** Bot chủ động dò tìm và quét các máy tính nằm chung trong dải dải mạng nội bộ (LAN/Subnet) của nó để lây lan theo chiều ngang với tốc độ cực nhanh do không bị chặn bởi tường lửa biên (p. 24).

- **Permutation Scanning (Quét hoán vị):** Sử dụng một thuật toán danh sách hoán vị giả ngẫu nhiên (pseudorandom permutation list) để phân chia dải IP cho các Bot khác nhau, đảm bảo không có hai Bot nào quét trùng một địa chỉ IP, tối ưu hóa hiệu suất lây nhiễm (p. 24).

CHƯƠNG VI: CÁC KỸ THUẬT PHÁT HIỆN TẤN CÔNG DOS/DDOS (DETECTION TECHNIQUES)

Mục tiêu cốt lõi của các kỹ thuật phát hiện là xác định và phân biệt chính xác giữa sự gia tăng lưu lượng truy cập bất hợp pháp và các sự kiện tăng trưởng lưu lượng hợp pháp (Flash Crowd) (p. 40). Tất cả các thuật toán phát hiện đều định nghĩa một cuộc tấn công là một sự lệch hướng bất thường và có thể nhận biết được so với ngưỡng thống kê lưu lượng mạng thông thường (p. 40).

1. Kỹ thuật Lập hồ sơ hoạt động (Activity Profiling)

- **Nguyên lý hoạt động:** Phương pháp này thực hiện giám sát liên tục thông tin tiêu đề (header) của các gói tin mạng để xây dựng nên một hồ sơ hành vi tiêu chuẩn (p. 41). Hồ sơ này dựa trên tốc độ gói tin trung bình (average packet rate) của một luồng mạng (network flow) — luồng này bao gồm các gói tin liên tiếp có các trường dữ liệu tương đồng (p. 41).
- **Dấu hiệu nhận biết tấn công:** Hệ thống an ninh mạng sẽ kích hoạt cảnh báo tấn công khi xuất hiện đồng thời hai chỉ số thống kê sau:
 - Sự gia tăng mạnh mẽ về mức độ hoạt động bên trong các cụm luồng mạng hiện tại (p. 41).
 - Sự gia tăng đột biến về tổng số lượng các cụm luồng riêng biệt (đặc trưng của mô hình DDoS phân tán từ nhiều nguồn IP khác nhau) (p. 41).

2. Kỹ thuật Phân tích tín hiệu dựa trên Wavelet (Wavelet-based Signal Analysis)

- **Nguyên lý phổ tín hiệu:** Kỹ thuật này coi lưu lượng mạng như một tín hiệu số liên tục và sử dụng phép biến đổi phổ để mô tả tín hiệu đầu vào dưới dạng các thành phần phổ (spectral components) (p. 42). Wavelet có lợi thế vượt trội nhờ khả năng cung cấp đồng thời mô tả về cả miền thời gian (time) và miền tần số (frequency) của luồng dữ liệu (p. 42).
- **Cơ chế xác định dị biệt:** Bằng cách phân tích năng lượng (energy) của từng cửa sổ phổ tín hiệu (spectral window), thuật toán sẽ phát hiện ra sự hiện diện của các điểm dị

biệt (p. 42). Tiến trình phân tích tín hiệu này giúp xác định chính xác thời điểm mà các thành phần tần số bất thường xuất hiện, từ đó cô lập cuộc tấn công (p. 42).

3. Thuật toán phát hiện điểm thay đổi tuần tự (Sequential Change-Point Detection)

Thuật toán này chia quy trình xử lý dữ liệu mạng thành 4 bước quản lý logic (p. 43):

- **Isolate Traffic (Cô lập lưu lượng):** Áp dụng các thuật toán phát hiện điểm thay đổi để tách biệt hoàn toàn các biến động trong số liệu thống kê lưu lượng mạng gây ra bởi cuộc tấn công (p. 43).
- **Filter Traffic (Lọc lưu lượng):** Thực hiện lọc dữ liệu lưu lượng mục tiêu theo các tiêu chí địa chỉ IP, cổng kết nối (port), hoặc giao thức (protocol), sau đó lưu trữ kết quả dưới dạng một chuỗi thời gian (time series) (p. 43).
- **Identify Attack (Nhận diện tấn công):** Sử dụng thuật toán lũy kế cộng dồn (Cusum algorithm) để tính toán độ lệch giữa giá trị trung bình cục bộ thực tế thu được so với giá trị kỳ vọng trong chuỗi thời gian, từ đó định vị chính xác cuộc tấn công DoS (p. 43).
- **Identify Scan Activity (Nhận diện hoạt động quét):** Thuật toán này còn được cấu hình mở rộng để phát hiện sớm các hoạt động dò quét mạng đặc trưng của các loại sâu máy tính (network worms) khi chúng tìm đường lây lan (p. 43).

CHƯƠNG VII: CHIẾN LƯỢC VÀ CÔNG CỤ ỨNG PHÓ TRONG PHÒNG VỆ (COUNTERMEASURES)

1. Ba chiến lược ứng phó cốt lõi (Countermeasure Strategies)

Khi đối mặt với các cuộc tấn công từ chối dịch vụ, tổ chức cần triển khai các chiến lược phòng vệ theo tầng nấc để giảm thiểu tối đa thiệt hại cấu trúc hạ tầng (p. 44):

- **Hấp thụ cuộc tấn công (Absorbing the Attack):**
 - *Giải pháp:* Sử dụng năng lực phần cứng và băng thông dự phòng bổ sung để hứng chịu và phân rã lưu lượng tấn công (p. 44).
 - *Yêu cầu:* Đòi hỏi phải có kế hoạch thiết kế hạ tầng từ trước (Preplanning) và tiêu tốn nhiều tài nguyên hệ thống (Additional resources) như mạng phân phối nội dung (CDN) hay định tuyến Anycast (p. 44).
- **Hạ cấp dịch vụ (Degrading Services):**
 - *Giải pháp:* Hệ thống tự động phân loại để xác định các dịch vụ cốt lõi (critical services), đồng thời chủ động tạm dừng hoặc ngắt bỏ hoàn toàn các dịch vụ không thiết yếu (non-critical services) nhằm giải phóng tài nguyên cho hệ thống trực (p. 44).
- **Tắt hoàn toàn dịch vụ (Shutting Down the Services):**
 - *Giải pháp:* Biện pháp cuối cùng khi mọi rào chắn bị phá vỡ là chủ động tắt toàn bộ tất cả các dịch vụ của hệ thống cho đến khi cuộc tấn công lắng xuống (subsided) (p. 44). Mục đích là để bảo vệ toàn vẹn dữ liệu hệ thống, ngăn ngừa nguy cơ xung đột phần cứng hoặc sập nguồn vật lý (p. 44).

2. Các phân hệ công cụ phòng chống chuyên dụng (DoS/DDoS Protection Tools)

Để hiện thực hóa các chiến lược phòng vệ, chuyên gia bảo mật sử dụng 4 phân hệ hạ tầng công nghệ:

- **Hệ thống tường lửa thế hệ mới (Next-Gen Firewalls - NGFW):** Thiết lập các luật chặn (Drop) các gói tin có dấu hiệu giả mạo IP nguồn hoặc vượt ngưỡng thiết lập kết nối (Rate Limiting).
- **Thiết bị lọc DDoS chuyên dụng (DDoS Mitigation Appliances):** Đặt tại cửa ngõ của trung tâm dữ liệu để thực hiện kỹ thuật "Scrubbing Center" - lọc sạch lưu lượng rác, chỉ cho lưu lượng hợp lệ đi qua hệ thống mạng nội bộ.
- **Hệ thống phát hiện/ngăn ngừa xâm nhập (IDS/IPS):** Áp dụng các bộ chữ ký (signatures) của các công cụ DoS/DDoS phổ biến để ngăn chặn ngay từ tầng mạng.
- **Dịch vụ bảo vệ dựa trên đám mây (Cloud-based Scrubbing Services):** Tận dụng băng thông khổng lồ từ các nhà cung cấp đám mây chuyên dụng để hấp thụ hoàn toàn các cuộc tấn công Volumetric lên tới hàng trăm Gbps trước khi chúng tiếp cận máy chủ gốc.

CHƯƠNG VIII: QUY TRÌNH KIỂM THỬ XÂM NHẬP DOS/DDOS (PENETRATION TESTING)

Kiểm thử xâm nhập DoS/DDoS (Penetration Testing) là quá trình chủ động giả lập các kịch bản tấn công thực tế một cách có kiểm soát nhằm đánh giá sức chịu đựng của hạ tầng công nghệ và năng lực phản ứng của đội ngũ an ninh (SOC) (p. 2).

[Bước 1: Chấp thuận pháp lý] —> [Bước 2: Thu thập thông tin] —> [Bước 3: Chọn kịch bản & Công cụ]

|

[Bước 6: Khôi phục & Báo cáo] <— [Bước 5: Tấn công leo thang] <— [Bước 4: Thiết lập giám sát]

Bước 1: Giành quyền chấp thuận bằng văn bản (Written Permission & SLA)

- **Yêu cầu bắt buộc:** Chuyên gia kiểm thử tuyệt đối không thực hiện bất kỳ hành vi gửi gói tin thử nghiệm nào nếu không có văn bản ủy quyền pháp lý có chữ ký của cấp có thẩm quyền quản lý hệ thống.
- **Thỏa thuận mức dịch vụ (SLA):** Xác định rõ khung giờ thực hiện (thường vào giờ thấp điểm hệ thống), dải IP nguồn dùng để tấn công, và thiết lập kênh liên lạc khẩn cấp (Hotline) với đội ngũ vận hành hệ thống nếu xảy ra sự cố sập nguồn vật lý ngoài ý muốn.

Bước 2: Thu thập thông tin và xác định bề mặt tấn công (Reconnaissance)

- **Xác định mục tiêu:** Sử dụng các kỹ thuật quét mạng thụ động và chủ động để xác định kiến trúc sơ đồ mạng, dải IP công cộng (Public IP), vị trí đặt tường lửa, bộ cân bằng tải (Load Balancer) và loại hệ điều hành của máy chủ mục tiêu.
- **Định vị dịch vụ:** Tìm kiếm các cổng dịch vụ đang mở (Open ports), đặc biệt là các cổng chạy dịch vụ Web (80, 443) hoặc các dịch vụ sử dụng giao thức UDP để đánh giá nguy cơ tiềm ẩn.

Bước 3: Lập kịch bản và lựa chọn công cụ phù hợp

- **Kịch bản Tầng mạng (Network Layer):** Sử dụng các công cụ như LOIC hoặc Dereil để giả lập tấn công SYN Flood hoặc UDP Flood nhằm kiểm tra giới hạn của thiết bị định tuyến, thiết bị tường lửa (pp. 34, 36).
- **Kịch bản Tầng ứng dụng (Application Layer):** Sử dụng DoSHTTP hoặc HULK để gửi các yêu cầu liên tục tới các URL nặng (như tính năng truy vấn cơ sở dữ liệu, tìm kiếm sản phẩm) nhằm vắt kiệt CPU/RAM của máy chủ Web (pp. 35-36).

Bước 4: Thiết lập môi trường giám sát nền (Monitoring Baseline)

- Trước khi phát lệnh tấn công, hệ thống giám sát tài nguyên (như Zabbix, Grafana, PRTG hoặc hệ thống giám sát nội bộ) phải được kích hoạt để đo lường các thông số nền khi hệ thống hoạt động bình thường: Tốc độ CPU (%), dung lượng RAM tiêu thụ (GB), băng thông mạng hiện tại (Mbps), và thời gian phản hồi (Response Time) của người dùng hợp lệ.

Bước 5: Thực hiện tấn công leo thang có kiểm soát (Execution)

- Tiến hành kích hoạt công cụ và nâng dần mức độ tấn công theo từng giai đoạn (ví dụ: bắt đầu với 50 requests/s, tăng dần lên 500, 5,000, và 50,000 requests/s).
- Ghi nhận chính xác "**Ngưỡng phá vỡ**" (**Breaking Point**) — thời điểm mà hệ thống bắt đầu xuất hiện tình trạng chậm mạng, không phản hồi kết nối hoặc trả về lỗi cấu hình máy chủ quá tải (502 Bad Gateway / 504 Gateway Timeout).

Bước 6: Khôi phục hệ thống và lập báo cáo kiến nghị (Remediation & Reporting)

- **Khôi phục:** Ngừng toàn bộ các tiến trình, công cụ giả lập tấn công. Phối hợp với đội ngũ quản trị hệ thống để kiểm tra trạng thái hoạt động, đảm bảo hệ thống tự động phục hồi hoặc khởi động lại các dịch vụ một cách an toàn.
- **Lập báo cáo:** Thống kê chi tiết các điểm yếu đã phát hiện (ví dụ: kích thước hàng đợi listen queue của giao thức TCP quá nhỏ dẫn đến dễ bị SYN Flood) (p. 13). Đề xuất giải pháp cấu hình tối ưu hóa khả năng bảo mật như bật tính năng SYN Cookies, cấu hình Rate Limiting trên Web Server.

CHƯƠNG IX: PHÂN TÍCH CHUYÊN SÂU KIẾN TRÚC VÀ CƠ CHẾ KHUẾCH ĐẠI TRONG TẤN CÔNG PHẢN XẠ (DRDOS AMPLIFICATION METRICS)

Để phân tích rõ lý do tại sao tấn công Phản xạ Phân tán (DRDoS) lại có sức tàn phá khủng khiếp lên bảng thông hệ thống, báo cáo cần đi sâu vào bản chất của hệ số khuếch đại (Amplification Factor) (p. 18).

1. Bản chất kỹ thuật của việc lựa chọn giao thức UDP

- Kẻ tấn công không sử dụng giao thức TCP cho các cuộc tấn công phản xạ vì TCP bắt buộc phải qua quy trình bắt tay 3 bước. Nếu giả mạo IP nguồn, gói tin SYN-ACK phản hồi sẽ bị gửi về máy nạn nhân, nhưng do không nhận được gói tin ACK thứ 3, kết nối sẽ bị hủy và không thể kích hoạt luồng dữ liệu phản hồi lớn.
- Ngược lại, giao thức UDP (User Datagram Protocol) là giao thức không hướng kết nối. Nó không có cơ chế kiểm tra tính xác thực của địa chỉ IP nguồn. Điều này cho phép kẻ tấn công dễ dàng gửi một gói tin yêu cầu (Request) kích thước nhỏ, nhưng cấu hình trường IP nguồn trong tiêu đề gói tin thành IP của nạn nhân (p. 18). Máy chủ phản xạ (Reflector) khi nhận được sẽ tự động gửi gói tin trả lời (Response) thẳng về phía nạn nhân với dung lượng lớn hơn gấp nhiều lần (p. 18).

2. Bảng thống kê hệ số khuếch đại của các giao thức phổ biến

Hệ số khuếch đại được tính bằng công thức:

$$\text{Hệ số khuếch đại} = \frac{\text{Kích thước gói tin Response (Bytes)}}{\text{Kích thước gói tin Request (Bytes)}}$$

Các thông số định lượng thực tế của các giao thức được thể hiện trong bảng dưới đây:

Tên giao thức (Protocol)	Cổng dịch vụ (Port)	Kích thước Request trung bình	Kích thước Response tối đa	Hệ số khuếch đại trung bình
NTP (Network Time Protocol)	UDP 123	48 Bytes	24,000 Bytes	~556.9 lần
DNS (Domain Name System)	UDP 53	64 Bytes	3,500 Bytes	~28 đến 54 lần
Memcached	UDP 11211	15 Bytes	750,000 Bytes	~10,000 đến 50,000 lần
SSDP (Simple Service Discovery)	UDP 1900	300 Bytes	9,000 Bytes	~30 lần

- **Phân tích trường hợp NTP (Monlist Attack):** Kẻ tấn công gửi lệnh monlist (yêu cầu máy chủ NTP trả về danh sách 600 máy tính đã kết nối với nó gần đây nhất). Một gói tin yêu cầu chỉ vỏn vẹn 48 Bytes từ kẻ tấn công có thể kích hoạt một chuỗi các

gói tin phản hồi nặng tới 24 KB gửi dồn dập về máy nạn nhân, khiến băng thông đường truyền của nạn nhân lập tức bị bóp nghẹt hoàn toàn.

CHƯƠNG X: QUY TRÌNH GIÁM SÁT VÀ ĐIỀU TRA SỰ CỐ DDOS DÀNH CHO ĐỘI NGŨ AN NINH (SOC DRILL)

Khi hệ thống đang chịu trận trước một trận lụt dữ liệu, đội ngũ vận hành an ninh (SOC) sẽ thực hiện quy trình điều tra phản ứng nhanh theo các bước thực tế dưới đây.

Bước 1: Trích xuất gói tin bằng công cụ lệnh TSHARK

Khi hệ thống có dấu hiệu hoạt động bất thường hoặc chậm mạng (Slow network performance), kỹ sư SOC sẽ chạy lệnh sau trên thiết bị gateway để bắt các gói tin nghi ngờ trong vòng 10 giây (p. 5):

```
bash
```

```
tshark -i eth0 -a duration:10 -w ddos_investigation.pcap
```

Hãy thận trọng khi sử dụng mã.

- -i eth0: Lắng nghe trên card mạng chính kết nối trực tiếp với Internet.
- -a duration:10: Tự động dừng tiến trình bắt gói tin sau đúng 10 giây để tránh làm đầy phân vùng ổ cứng khi lưu lượng mạng quá lớn.
- -w ddos_investigation.pcap: Xuất toàn bộ dữ liệu gói tin thô ra file định dạng .pcap để phân tích chuyên sâu.

Bước 2: Phân tích thống kê tìm địa chỉ IP nguồn tấn công

Sử dụng câu lệnh sau để lọc và tìm ra top 10 địa chỉ IP gửi nhiều gói tin nhất vào hệ thống trong thời gian diễn ra sự cố:

bash

```
tshark -r ddos_investigation.pcap -T fields -e ip.src | sort | uniq -c | sort -rn | head -n 10
```

Hãy thận trọng khi sử dụng mã.

- **Cơ chế hoạt động:** Lệnh này đọc file pcap, trích xuất duy nhất trường IP nguồn (ip.src), sau đó nhóm các địa chỉ IP trùng nhau lại và đếm số lần xuất hiện (uniq -c), cuối cùng sắp xếp giảm dần (sort -rn) để hiển thị ra các địa chỉ IP đang thực hiện flood dữ liệu rác vào máy chủ (p. 5).

Bước 3: Cấu hình quy tắc tường lửa IPTABLES để chặn khẩn cấp

Sau khi xác định được hành vi tấn công flood, kỹ sư áp dụng ngay các luật chặn cứng ở tầng nhân hệ điều hành (Kernel) (p. 5):

- *Luật 1: Giới hạn số lượng kết nối tối đa từ một IP chỉ được 20 kết nối đồng thời nhằm chống Service Request Floods (p. 11):*

bash

```
iptables -A INPUT -p tcp --syn --dport 80 -m connlimit --connlimit-above 20 -j DROP
```

Hãy thận trọng khi sử dụng mã.

- *Luật 2: Chặn hoàn toàn các gói tin ICMP Echo rác để giải phóng băng thông đường truyền (Bandwidth Attacks) (p. 10):*

bash

```
iptables -A INPUT -p icmp --icmp-type echo-request -j DROP
```

Hãy thận trọng khi sử dụng mã.

CHƯƠNG XI: MA TRẬN SO SÁNH GIỮA CÁC CÔNG CỤ TẤN CÔNG DOS/DDOS PHỔ BIẾN PHƯƠNG PHÁP LUẬN VÀ KẾT LUẬN BÁO CÁO

Để nội dung báo cáo rõ ràng, chi tiết, dưới đây là ma trận đối sánh kỹ thuật trực quan giữa các công cụ tấn công phổ biến được đề cập trong tài liệu CEH (p. 2):

Tiêu chí so sánh	Pandora DDoS Toolkit	High Orbit Ion Cannon (HOIC)	DoSHTTP	AnDOSid (Mobile)
Tầng mạng mục tiêu	Tầng Giao vận & Ứng dụng	Chủ yếu tầng Ứng dụng	Tầng Ứng dụng (HTTP)	Tầng Ứng dụng di động
Phương thức tấn công	HTTP min, download, combo, socket connect, max flood (p. 33)	Gửi luồng HTTP POST/GET với tệp Booster mở rộng (p. 34)	Lập lịch HTTP Flood bằng cơ chế Asynchronous Sockets (p. 35)	Giả lập HTTP POST Flood từ thiết bị cầm tay (p. 37)
Nền tảng thực thi	Quản lý qua Web Panel (Botnet) (p. 33)	Phần mềm chạy trên	Phần mềm giao diện Windows (p. 35)	Ứng dụng chạy trên hệ điều

		Windows/Linux (p. 34)		hành Android (p. 37)
Tính năng đặc biệt	Biến thể từ Dirt Jumper, quản lý trạng thái đa luồng bot (p. 33)	Cho phép cấu hình số lượng Thread thủ công và port tự chọn (p. 34)	Tích hợp sẵn URL verification, theo dõi hiệu năng hệ thống (p. 35)	Dành riêng cho chuyên gia kiểm thử ứng dụng di động (p. 37)

1. Phương pháp luận phòng thủ toàn diện

Qua quá trình phân tích chi tiết, an toàn thông tin không phải là một trạng thái tĩnh mà là một quy trình vận động liên tục. Để bảo vệ tài sản số của tổ chức trước hiểm họa DoS/DDoS, không thể chỉ phụ thuộc vào một thiết bị đơn lẻ mà cần triển khai mô hình phòng thủ chiều sâu (Defense-in-Depth):

- **Ở tầng mạng lõi:** Sử dụng dịch vụ định tuyến Anycast kết hợp với hệ thống trung tâm lọc rửa lưu lượng (Scrubbing Center) của các nhà cung cấp đám mây lớn nhằm hấp thụ hoàn toàn các cuộc tấn công Volumetric lên tới hàng trăm Gbps trước khi luồng dữ liệu chạm tới cổng trung tâm dữ liệu của tổ chức (p. 9).
- **Ở tầng biên hệ thống:** Triển khai các thiết bị IPS chuyên dụng cấu hình bộ luật chữ ký để nhận diện và loại bỏ ngay lập tức cấu trúc tiêu đề gói tin dị biệt của các công cụ flood tự động.
- **At tầng ứng dụng:** Tối ưu hóa chất lượng mã nguồn hệ thống, cấu hình hệ thống bộ nhớ đệm (Caching) thông minh để giảm tải xử lý truy vấn cho cơ sở dữ liệu phía sau,

triệt tiêu nguy cơ bị khai thác cạn kiệt tài nguyên bởi các câu lệnh SQL độc hại (p. 17).

2. Kết luận

Nghiên cứu toàn diện về Module 09: Denial-of-Service trong chương trình Certified Ethical Hacker (CEH) cho thấy các cuộc tấn công từ chối dịch vụ đã tiến hóa vượt bậc (p. 1). Chúng không còn là những hành vi phá hoại tự phát nhỏ lẻ mà đã trở thành những chiến dịch có tổ chức, sử dụng hạ tầng tội phạm công nghệ cao phức tạp (p. 20). Việc chủ động triển khai công tác Đánh giá kiểm thử xâm nhập (Penetration Testing) định kỳ chính là chìa khóa cốt lõi giúp tổ chức phát hiện sớm các lỗ hổng kiến trúc mạng, đo lường chính xác sức chịu đựng của hệ thống để đưa ra các phương án nâng cấp hạ tầng kịp thời, đảm bảo tính liên tục của dịch vụ và an toàn thông tin cho tổ chức (p. 2).

PHỤ LỤC A: TỪ ĐIỂN THUẬT NGỮ KỸ THUẬT CHUYÊN SÂU (GLOSSARY)

1. **DoS (Denial of Service):** Tấn công từ chối dịch vụ nhắm vào máy tính hoặc hạ tầng mạng nhằm ngăn chặn hoàn toàn khả năng truy cập tài nguyên của người dùng hợp lệ (p. 5).
2. **DDoS (Distributed Denial of Service):** Tấn công từ chối dịch vụ phân tán, sử dụng một số lượng lớn các hệ thống máy tính bị chiếm quyền điều khiển cùng đồng loạt flooding vào một mục tiêu (p. 6).
3. **Botnet:** Mạng lưới gồm các máy tính, thiết bị công nghệ (IoT) đã bị nhiễm mã độc và bị kiểm soát từ xa bởi kẻ tấn công thông qua máy chủ C&C (p. 21).

4. **Zombie:** Thuật ngữ chỉ một máy tính cá nhân hoặc máy chủ của người dùng phổ thông đã bị dính mã độc và tham gia phát tán luồng tấn công DDoS theo lệnh (p. 7).
5. **C&C Center (Command and Control Center):** Cơ sở hạ tầng máy chủ do tội phạm mạng thiết lập để gửi lệnh độc hại đến mạng lưới Botnet (p. 21).
6. **Phlashing (Permanent DoS):** Hình thức tấn công phá hoại vĩnh viễn thiết bị vật lý bằng cách gửi các bản cập nhật Firmware giả mạo chứa mã độc (bricking hệ thống) (p. 15).
7. **DRDoS (Distributed Reflection Denial of Service):** Tấn công từ chối dịch vụ phản xạ phân tán, sử dụng các máy chủ trung gian để phản xạ và khuếch đại luồng dữ liệu tấn công về phía nạn nhân (p. 18).
8. **SYN Cookies:** Cơ chế phòng vệ tầng mạng, mã hóa thông tin trạng thái vào số thứ tự (Sequence Number) của gói tin SYN-ACK để chống lại tấn công SYN Flood mà không cần cập phát bộ nhớ trước.
9. **Three-way Handshake:** Quy trình bắt tay 3 bước tiêu chuẩn để thiết lập một kết nối tin cậy qua giao thức TCP (gồm các gói tin SYN $\rightarrow$ SYN-ACK $\rightarrow$ ACK) (p. 12).
10. **Rate Limiting:** Giải pháp an ninh giới hạn số lượng yêu cầu kết nối tối đa mà một địa chỉ IP được phép gửi đến máy chủ trong một đơn vị thời gian cố định.

PHỤ LỤC B: DANH MỤC TÀI LIỆU THAM KHẢO

1. EC-Council, *Certified Ethical Hacker (CEH) Version 9 Courseware - Module 09: Denial-of-Service*, 2014-2015 (p. 1).
2. Verisign, *DDoS Trends Report - Q4 2014*, Toàn văn nghiên cứu về xu hướng tăng trưởng kích thước tấn công lên mức trung bình 7.39 Gbps (p. 4).
3. Cisco Systems, *Defending Against Distributed Denial of Service (DDoS) Attacks*, Hướng dẫn cấu hình thiết bị định tuyến chống nghẽn băng thông hệ thống.
4. IETF (Internet Engineering Task Force), *RFC 4987: TCP SYN Flooding Attacks and Common Mitigations*, Phân tích chi tiết lỗ hổng listen queue của giao thức TCP.